

Security and Privacy Awareness and Training Policy

(insert company name here)

Version (add number)

Effective Date: (add the date when the plan is adopted)

Last Revision Date: (add the date of the last revision of the document)

Table of Contents

1. OVERVIEW	3
Purpose	Error! Bookmark not defined.
Scope	3
2. POLICY	4
Management Commitment	5
Roles and Responsibilities	5
Coordination Among Organizational Entities	5
3. COMPLIANCE	6
Security Training	6
Security Training Records	6
REFERENCES	7

1. OVERVIEW

Security awareness and training is an important aspect of protecting the confidentiality, integrity, and availability (CIA) of sensitive information. Employees are the first line of defense and must be made aware of the security risks which can arise during normal operations at *(insert company name here)*.

Purpose

(Insert company name here) understands that people are often the biggest threat, whether intentionally or inadvertently, to the security of sensitive information. As such, all users of information systems must be made aware of the security risks associated with their activities.

Some possible security risks associated with *(insert company name)* business operations are:

- Phishing scams to gain unauthorized access to *(insert company name here)* assets
- Unauthorized access of restricted areas at the company
- Unsecured networks permitting unauthorized access to company data
- *(This isn't an exhaustive list. Insert additional elements based on your company's specific activity.)*

Scope

This Security and Privacy Awareness and Training Policy applies to all employees, contractors, and anyone else who is required to perform business functions on behalf of *(insert company name here)*.

(Insert company name here) will also conduct *(Recommended: annual)* refresher training for all employees, as well as anytime there are significant changes to the environment. Employees should remain vigilant in their security awareness outside of training sessions.

This policy will be reviewed on an annual basis or whenever there are significant changes to the environment.

2. POLICY

All employees, contractors, and anyone accessing (insert company name) information systems must understand how to protect private company data.

Private data may include:

- Passwords and usernames used to access business systems and applications
- Documents and files created by or purchased by (insert company name)
- Client-specific information and data
- Personally Identifiable Information (SINs, addresses, names, DOBs, etc.)

(Insert company name here) will ensure that all employees are given security and privacy awareness training during the new hire process and before accessing any (insert company name here) systems. This training reflects common security and privacy awareness specific to the (insert company name here) environment.

Training includes, but is not limited to, the following:

- Physical access
- Restricted areas
- Potential incidents
- How to report incidents
- Laptop best practices
- How to spot a phishing scam

Furthermore, all employees will be enrolled in online Security Awareness Training courses. Courses will be provided via the employee's business email address, will occur (Select quarterly, monthly, or weekly), and must be completed within (Recommendation: two weeks).

New employees will be enrolled in Security Awareness Training courses and must have their first course completed within the first (Recommendation: 30 days) of employment. Employees are required to complete all Security Awareness courses and pass the subsequent exam.

Management Commitment

(Insert company name here)'s senior management will commit to the development of a security awareness program allocating staff and resources. The (Add: Job title of the person managing this initiative, such as an information security manager) will have access to reports relating to the completion of all assigned Security Awareness Training Courses.

Roles and Responsibilities

All employees and contractors are responsible for understanding and following all security-related policies and procedures. If needed, employees should ask their manager (If applicable: or assigned Security Officer) for clarification on any of the security policies.

Managers are responsible for ensuring all employees complete the required security training.

Employees are asked to report any violation of this policy or suspicious activity to their immediate supervisor. Any questions should be immediately directed to (insert email address).

Coordination Among Organizational Entities

(Insert company name here) employees and contractors will work together to ensure that required security controls are in place, are maintained, and comply with the policy described in this document.

Security concerns, incidents, or suspected/confirmed vulnerabilities will be shared with appropriate personnel in the organization so that the vulnerability can be remediated (or mitigated with compensating security controls), and we can ensure that similar vulnerabilities in other systems or processes can be addressed.

3. COMPLIANCE

Compliance with the policy defined in this document is mandatory. Failure to comply with (insert company name here)'s Security Awareness and Training Policy may result in disciplinary actions up to and including termination of employment.

Employees may also be held personally liable for any violations of this policy.

Failure to comply with any (insert company name here) Information Security Policies may result in termination of contracts for contractors, partners, consultants, and other entities. Legal actions may also be taken for violations of applicable regulations and laws. Systems that do not satisfy (insert company name here) Information Security Policy requirements may be prevented from being allowed to operate as a production system.

(The language in the compliance section is strict due to industry-regulated or legal ramifications of security breaches. It should be adjusted to fit your company's requirements.)

Security Training

(Insert company name here) must provide role-based, security-related training before authorizing access to the system or performing assigned duties, as well as when required by a system change or changes in personnel roles.

(Insert company name here) must provide security training materials that address the procedures and activities necessary to fulfill the defined roles and responsibilities for information system security.

(Insert company name here) must also provide role-based, security-related training to all appropriate personnel at least once every (Recommended: three years). Appropriate personnel includes but is not limited to System Administrators, Database Administrators, Network Engineers, Security Analysts, and the CISO (These roles should be adjusted to better suit your company).

The employee or consultant shall acknowledge having received the role-based training either in writing or electronically as part of the training course completion.

Security Training Records

(Insert company name here) must create security training documents and distribute them to users.

The (Job title of the person managing this initiative, such as an information security manager) must ensure activities for monitoring and documenting basic security awareness training, as well as role-based training, are conducted.

Employees and contractors must provide evidence of successful course completion (such as certificates) to the (Job title of the person managing this initiative). All security training records must be stored for (Recommended: at least 5 years).